ARTE DE AMAR

DOCUMENTAÇÃO DO SISTEMA

Referência da *API*

Rotas, formatos de pedido e resposta, erros e sessão.

Site e painel da OSC Arte de Amar
Palmas, Tocantins · Projeto Integrador 1 · Sistemas de Informação · UNITINS

Versão 1.1.0
03 de novembro de 2026

ARTE DE AMAR

Referência da API

Rotas, formatos de pedido e resposta, erros e sessão.

Base: `https://arte-de-amar-site.pages.dev/api`. Tudo em JSON e UTF-8, exceto o upload de foto (multipart) e a entrega de foto (a imagem).

Os formatos abaixo são os mesmos validados pelos contratos de `tests/contratos.ts`.

Convenções

Erro. Todo erro sai no mesmo formato, com a mensagem em português, pronta para mostrar na tela:

```
{ "erro": "Preencha o campo \"Nome\"." }
```

status	quando
400	dado inválido (a mensagem diz qual campo)
401	sem sessão, sessão expirada ou login errado
403	pedido de outra origem (CSRF) ou senha temporária ainda não trocada
404	rota, recurso ou registro inexistente
405	método não suportado na rota
409	conflito: outra pessoa salvou antes, foto em uso, e-mail repetido
413	corpo ou arquivo grande demais
415	`Content-Type` errado ou formato de imagem não aceito
429	muitas tentativas (login ou inscrição)
500	erro do servidor, sem detalhe interno na resposta

Sessão. O login devolve o cookie `ada_sessao` (`HttpOnly`, `SameSite=Strict`, `Secure` em HTTPS, `Path=/api`, 8 horas). O navegador manda sozinho; nenhuma rota recebe token no corpo ou no cabeçalho.

CSRF. Em `/api/admin/*`, todo método que altera dados com cabeçalho `Origin` diferente do site é recusado com 403.

Datas. Sempre UTC, no formato do SQLite: `2026-11-03 16:53:22`.

Público

`GET /conteudo`

Tudo que o site mostra e a diretoria edita, numa ida ao banco. Só itens visíveis, na ordem do painel. Sem cache.


```
{
  "projetos": [
    {
      "nome": "Volta às Aulas",
      "objetivo": "Mochila completa e material escolar entregue em mãos…",
      "objetivoCurto": "Mochila completa e material entregue em mãos…",
      "publico": "Estudantes da rede pública",
      "status": "Em andamento",
      "foto": { "src": "/assets/fotos/hero-menino-mochila.jpg", "alt": "Menino sorrindo…",
"largura": 1600, "altura": 2400, "posicao": "50% 30%" },
      "meta": [86, 120, "mochilas"],
      "depoimento": "“Ele escolheu a mochila dos Minions…”",
      "autor": "Avó atendida, 2026",
      "videoUrl": null
    }
  ],
  "marcos": [{ "ano": "2015", "titulo": "A fundação", "texto": "…", "textoDesktop": "…",
"foto": { "…": "…" }, "soDesktop": false }],
  "membros": [{ "nome": "Aline Milani", "cargo": "Presidente", "foto": { "…": "…" } }],
  "numeros": [{ "valor": 11, "sufixo": "", "label": "anos de atuação" }],
  "config": { "whatsapp": "5563999999999", "pix": "40.019.106/0001-51" },
  "textos": { "hero.subtitulo": "Texto trocado no painel", "footer.foto": { "src":
"/api/midias/14", "…": "…" } }
}
```


`meta` é `[feito, total, unidade]` ou `null`. Em `textos` só aparecem os campos que a diretoria trocou; campo de foto já vem como objeto.

`POST /voluntarios`

Formulário "Ser voluntário".


```
{ "nome": "Maria Souza", "whatsapp": "(63) 98877-6655", "como": "Natal Solidário", "site":
"" }
```


`201 { "ok": true }`. O telefone é guardado só com dígitos. `site` é o campo-isca: se vier preenchido, a resposta é a mesma e nada é gravado. Limite de 5 inscrições por hora por IP (429).

`GET /midias/:id`

A foto enviada pelo painel, com `Cache-Control: immutable` de um ano e `X-Content-Type-Options: nosniff`. Foto do site original responde 302 para o arquivo em `/assets/fotos`. `?baixar=1` entrega como download, com nome tirado da descrição.

Sessão

`POST /auth/login`

```
{ "email": "aline@ong.org", "senha": "minha-senha" }
```

`200 { "usuario": { "id": 2, "nome": "Aline Milani", "email": "aline@ong.org", "trocarSenha": false } }` e o cookie. Senha errada e e-mail inexistente dão a mesma resposta (401). Depois de 5 erros no mesmo e-mail em 15 minutos, 429.

`POST /auth/logout`

Apaga o cookie. `200 { "ok": true }`.

`GET /auth/eu`

Quem está logado, no mesmo formato do login, ou 401.

Painel (`/admin`, exige sessão)

Com senha temporária pendente, tudo devolve 403, exceto `PUT /admin/senha`.

Cadastros: `projetos`, `marcos`, `membros`, `numeros`

método	rota	corpo	resposta
GET	`/admin/:entidade`		`{ itens: [...] }`, inclusive os ocultos, com `foto_url`
POST	`/admin/:entidade`	os campos	`201 { item }`, no fim da lista, versão 0
PUT	`/admin/:entidade/:id`	só os campos alterados + `versao`	`{ item }` com a versão nova
DELETE	`/admin/:entidade/:id`		`{ ok: true }`

método	rota	corpo	resposta
PUT	`/admin/:entidade/ordem`	`{ "ids": [3, 1, 2] }`	`{ ok: true }`

Versão (edição simultânea). O `PUT` com `versao` só grava se ela for a atual; senão responde 409 com quem salvou antes. Sem `versao` (o interruptor "No site"), vale o último.

```
PUT /api/admin/projetos/2
{ "meta_feito": 90, "versao": 4 }

409 { "erro": "Larissa Lima salvou uma mudança nesse projeto enquanto você editava. Feche, abra de novo…" }
```

Campos de cada cadastro (limites validados na API e no banco):

entidade	campos
projetos	`nome`* (80), `objetivo`* (400), `objetivo_curto`* (200), `publico`* (80), `status`* (`Em andamento` | `Concluído`), `foto_id`*, `foto_posicao`, `meta_feito`, `meta_total`, `meta_unidade` (os três juntos ou nenhum), `depoimento` (300), `autor` (80), `video_url` (https), `visivel`
marcos	`ano`* (10), `titulo`* (60), `texto`* (200), `texto_desktop`* (300), `foto_id`*, `foto_posicao`, `so_desktop`, `visivel`
membros	`nome`* (60), `cargo`* (60), `foto_id`, `visivel`
numeros	`valor`* (inteiro ≥ 0), `sufixo` (3), `label`* (40), `visivel`

* obrigatório. Entre parênteses, o máximo de caracteres.

Fotos

método	rota	corpo	resposta
GET	`/admin/midias`		`{ itens: [{ id, url, alt, largura, altura, bytes, estatica, usos, criado_em }] }`
POST	`/admin/midias`	multipart: `arquivo`, `alt`, `largura`, `altura`	`201 { item }`
PUT	`/admin/midias/:id`	`{ "alt": "…" }`	`{ ok: true }`
DELETE	`/admin/midias/:id`		`{ ok: true }`, ou 409 se em uso ou do site original

O tipo é conferido pelos primeiros bytes (JPEG, PNG, WebP). SVG e qualquer outra coisa: 415. Acima de 1,5 MB: 413. O painel já manda a foto reduzida para 1600px e em WebP.

Textos do site

método	rota	corpo	resposta
GET	`/admin/textos`		`{ valores: { chave: valor }, fotos: { chave: url } }`
PUT	`/admin/textos`	`{ "valores": { "hero.titulo": "Linha 1\nLinha |2|", "hero.foto": "14", "footer.frase": null } }`	`{ ok: true }`

As chaves válidas e os limites estão em `src/lib/textos.ts`. `null` volta o campo ao original. Um campo inválido barra o pacote inteiro.

Voluntários

método	rota	corpo	resposta
GET	`/admin/voluntarios`		`{ itens }`, novos primeiro
PUT	`/admin/voluntarios/:id`	`{ "status": "novo" | "contatado" | "arquivado" }`	`{ ok: true }`
DELETE	`/admin/voluntarios/:id`		`{ ok: true }`
DELETE	`/admin/voluntarios`		`{ apagados: n }`, só os arquivados

Usuários

método	rota	corpo	resposta
GET	`/admin/usuarios`		`{ itens: [{ id, nome, email, trocar_senha, criado_em, ultimo_acesso }] }`
POST	`/admin/usuarios`	`{ "nome": "…", "email": "…" }`	`201 { item, senhaTemporaria }`
PUT	`/admin/usuarios/:id`		`{ senhaTemporaria }` (esqueceu a senha)
DELETE	`/admin/usuarios/:id`		`{ ok: true }`; não vale para si mesmo nem para o último
PUT	`/admin/senha`	`{ "atual": "…", "nova": "…" }`	`{ ok: true }`; com senha temporária, `atual` não é pedida

A senha temporária tem o formato `kq7m-x3ra-p9ve` e aparece só nessa resposta. Tirar o acesso derruba a sessão da pessoa no próximo pedido.

Outros

método	rota	resposta
GET, PUT	`/admin/configuracoes`	`{ config: { whatsapp, pix } }`; o PUT completa o 55 do WhatsApp
GET	`/admin/auditoria?de=2026-11-03 03:00:00&ate=2026-11-04 03:00:00`	`{ itens: [{ id, usuario_id, usuario_nome, acao, area, alvo, detalhe, criado_em }] }`, até 2000
GET	`/admin/espaco`	`{ usado, limite, porcentagem, bytesFotos, fotosEnviadas, voluntarios }`